MDPI

Article

Policy-Private Healthcare Consent Enforcement on Public Blockchains via TPS-Assisted Zero-Knowledge Verification

Kun Li [1,*], Ankur Lohachab [1], Michel Dumontier [1] and Visara Urovi [1]

[1] Affiliation; e-mail@e-mail.com
* Correspondence: e-mail@e-mail.com

Abstract

In blockchain-based healthcare data sharing, consent policies are expected to be enforced in a verifiable and auditable manner. However, public blockchain transparency may expose sensitive policy information through on-chain representations, verification interfaces, and observable execution artifacts. Existing privacy-preserving solutions mainly protect data contents, user identities, or transaction details, but they insufficiently address the confidentiality of governing consent policies and policy-dependent leakage during enforcement. This paper studies policy-private consent enforcement for blockchain healthcare systems. We propose the Trusted Proof Service-assisted Zero-Knowledge Policy Interpreter (TPS-ZKPI), which enables authorization decisions to be verified while limiting leakage about policy content, policy identity, and policy structure and parameters. In TPS-ZKPI, the provider commits to a hidden consent policy on-chain and provisions policy-bound proving material to a Trusted Proof Service (TPS). The TPS constructs the witness from requester-submitted credentials and access context, generates a zero-knowledge proof of policy compliance, and the proof is verified on-chain against the policy commitment. TPS-ZKPI adopts an explicit off-chain trust boundary for confidential policy handling: policy confidentiality is conditional on the TPS preserving the secrecy of plaintext policy material and requester authorization evidence. Under this TPS trust assumption, zero-knowledge verification provides public auditability of authorization correctness without exposing the private witness to the blockchain. To reduce policy-dependent leakage through public verification artifacts, TPS-ZKPI combines fixed-length policy encoding, a reusable zero-knowledge policy interpreter, commitment-based policy binding, and public-chain transcript normalization. We evaluate TPS-ZKPI against metadata-only adversaries that observe public-chain artifacts and conduct inference attacks on policy content, policy identity, and policy structure and parameters. Under a multi-seed permutation-test criterion, no modeled supervised or unsupervised attack recovers hidden policy information above the chance baseline, and a paired gas-padding ablation attributes this protection specifically to gas-transcript normalization at a 38–40% gas overhead.

Keywords: blockchain; policy privacy; data use ontology; healthcare data sharing

Received:
Accepted:
Published:

Copyright: © 2026 by the authors. Submitted to *Blockchains* for possible open access publication under the terms and conditions of the Creative Commons Attribution (CC BY) license.

1. Introduction

Blockchain technology has emerged as a promising foundation for decentralized and auditable healthcare data sharing [1–3]. Its transparency and immutability enable verifiable consent enforcement and traceable authorization decisions, supporting cross-institutional accountability. At the same time, consent enforcement on public blockchains

may expose policy-dependent contextual information, even when the underlying health data remain encrypted [4,5].

In healthcare data sharing, a *consent policy* encodes the conditions under which a data subject authorizes others to access or use their health data, such as who may access the data, for what purpose, and under what constraints. Consent policies in healthcare are often privacy-sensitive [6]. For example, a policy based on biomedical data-use terms may reveal whether a dataset is restricted to disease-specific research, whether ethics approval is required, or whether access is limited to particular institutions or projects. If such policies are directly represented in smart contracts, embedded in verification logic, or reflected in public execution traces, unauthorized observers may infer information about the protected resource, the data subject's constraints, or the requester's authorization context.

Existing privacy-preserving blockchain solutions mainly protect data contents, user identities, or transaction details [7–9]. Encrypted data-sharing mechanisms such as attribute-based encryption and proxy re-encryption protect access to data [10,11], while zero-knowledge transaction systems hide asset ownership, values, or participant relationships [12]. Even mechanisms designed to hide policy content, such as hidden-policy attribute-based encryption [13], do not control the policy-dependent artifacts that a public chain exposes while enforcing the policy. None of these mechanisms protects the confidentiality of the policies that govern access decisions. In blockchain-based consent management, policy leakage may arise not only from explicit policy disclosure, but also from policy-dependent artifacts such as calldata size, public-input layout, emitted events, verifier interfaces, and gas usage. Therefore, policy-private consent enforcement requires more than hiding data or proving correctness in zero knowledge; it also requires controlling what the public-chain transcript reveals about the hidden policy.

This paper studies policy-private consent enforcement for blockchain-based healthcare data sharing under public-chain observability. The core problem is how to make consent enforcement publicly verifiable while preventing metadata-only public-chain observers from inferring the governing policy or requester authorization evidence from policy-dependent execution artifacts. We focus on Boolean-based consent policies, including policies derived from biomedical data-use conditions such as Data Use Ontology (DUO) terms [6] and disease-scope constraints [14]. In particular, an on-chain verifier should be able to check that a requester satisfies a provider-defined consent policy, while a metadata-only public-chain adversary learns minimal information from the resulting public verification transcript.

We address this problem with the Trusted Proof Service-assisted Zero-Knowledge Policy Interpreter (TPS-ZKPI). In TPS-ZKPI, the data provider (who can be seen as the data owner) commits to a hidden consent policy on-chain and provisions the corresponding policy-bound proving material to a Trusted Proof Service (TPS). The requester submits policy-relevant authorization evidence, such as attributes, credentials, and access context, to the TPS. The TPS constructs the private witness and generates a zero-knowledge proof showing that the requester satisfies the committed policy. The proof is then verified on-chain against the provider's policy commitment. This yields an auditable authorization outcome without exposing the policy logic to the public-chain transcript.

TPS-ZKPI combines the following design elements. First, it uses TPS-assisted proof generation to keep confidentiality-sensitive policy material and requester evidence outside the public-chain transcript. Second, it compiles heterogeneous Boolean-based consent policies into fixed-length Reverse Polish Notation (RPN) programs. Third, building on the standard commit-and-prove paradigm, it evaluates these programs through a reusable zero-knowledge policy interpreter that avoids policy-specific verifier contracts and supports policy evolution without changing the public verification interface. Fourth, it ap-

plies observability-aware transcript normalization to reduce policy-dependent variation in calldata, logs, public parameters, and gas-related behavior.

We evaluate TPS-ZKPI using attack-driven empirical analysis under a metadata-only threat model. The evaluation operationalizes policy privacy through three objectives: Policy Content Hiding (PCH), Policy Indistinguishability (PI), and Structure and Parameter Privacy (SPP). Supervised and unsupervised attacks test whether observable public-chain artifacts allow adversaries to recover hidden policy content, distinguish otherwise-equivalent policies, or infer structural and parameter properties. The results show that, after transcript normalization, no modeled attack recovers hidden policy information above the chance baseline under a multi-seed permutation-test criterion. A paired ablation serves as a positive control: when gas padding is removed, the same attackers recover policy-dependent signal, and that signal collapses under full normalization, isolating gas-transcript normalization as the mechanism responsible.

This paper makes the following contributions:

- We cast policy privacy under public-chain observability in blockchain-based healthcare data sharing as three measurable objectives—policy content hiding, policy indistinguishability, and structure/parameter privacy—each with an attack-based criterion, giving concrete evaluation targets for consent-policy enforcement.
- We propose TPS-ZKPI, a TPS-assisted zero-knowledge approach for publicly verifiable and auditable consent enforcement, in which on-chain proof verification and auditability hold without trusting the TPS, while policy confidentiality and faithful witness construction are conditional on an explicit, delimited trust assumption—keeping policy-bound proving material and requester authorization evidence off-chain.
- We design a reusable zero-knowledge policy interpreter for fixed-length Boolean RPN policy programs over a bounded token alphabet, combining policy commitment binding with a policy-independent on-chain verification interface that serves all policies through one circuit and supports policy evolution without changing the on-chain verifier.
- We provide an attack-driven empirical evaluation of residual policy-dependent leakage from normalized public-chain metadata on the Polygon Amoy testnet, using supervised classification and unsupervised clustering attacks under a multi-seed permutation-test criterion. A paired gas-padding ablation then isolates gas-transcript normalization as the mechanism responsible for the observed protection and quantifies its gas-cost overhead.

The remainder of this paper is organized as follows. Section 2 discusses related work and positions TPS-ZKPI against existing blockchain consent-management, privacy-preserving blockchain, hidden-policy, private policy-evaluation, reusable proving, and metadata-leakage approaches. Section 3 defines the system and trust model, the public-chain adversary, and the privacy objectives. Section 4 presents the TPS-ZKPI design. Section 5 reports the empirical evaluation. Section 6 discusses limitations and future work, and Section 7 concludes the paper.

2. Related Work

Table 1. Positioning of representative approaches against policy-private consent enforcement under public-chain observability. "Yes" indicates explicit support, "Partial" indicates indirect or incomplete support, and "No" indicates that the dimension is not addressed—typically because it lies outside the approach's original design goals; assumptions in parentheses are part of the claim.

Approach	Policy confidentiality	Metadata-leakage mitigation	Verifiable auditability	Main limitation
Blockchain consent management [1,2]	No	No	Yes	Records and enforces consent verifiably on chain, but policy confidentiality and policy-dependent leakage are typically out of scope.
Data / transaction privacy [7,8,15–17]	No	Partial	Partial	Protects encrypted data access or transaction semantics, but not the governing consent policy or policy-dependent authorization workflow.
Hidden-policy access control [13,18]	Partial	Partial	Partial	Reduces direct policy exposure, but may leak through workflows, updates, or policy-holder interactions.
MPC / HE policy evaluation [19,20]	Yes	No	Partial	Supports confidential computation, but usually lacks public-chain-verifiable authorization evidence.
Universal SNARKs / zkVMs [21–23]	No	Partial	Yes	Supports proof reuse and public verification, but does not by itself hide policy-dependent public artifacts.
Metadata-leakage defenses [24]	No	Yes	No	Models or mitigates observable signals, but does not provide hidden-policy consent enforcement.
TPS-ZKPI	Yes (under TPS trust)	Yes (modeled channels)	Yes	Provides policy-private, metadata-aware, verifiable consent enforcement under the stated TPS trust assumption.

Blockchain-based consent management for healthcare data sharing has been studied extensively, with smart contracts used to record, enforce, and audit consent across institutions [1–3]. This line of work focuses on making consent decisions verifiable and auditable, and the privacy mechanisms surveyed in this space mainly protect health data contents and user identities [5]. The confidentiality of the governing consent policy—and what public-chain enforcement artifacts reveal about it—is typically out of scope.

Beyond the consent-management setting, existing work addresses important fragments of policy-private consent enforcement, but not their combination under public-chain observability. Encrypted data-sharing mechanisms, such as Ciphertext-Policy Attribute-Based Encryption (CP-ABE) and proxy re-encryption (PRE) [15,16], control access to encrypted data. However, standard CP-ABE attaches the access policy to the ciphertext in the clear, exposing the policy itself, while PRE-based delegation may reveal authorization patterns that data encryption is not designed to hide. Transaction-privacy systems, including Zerocash-style protocols [17] and Ethereum-oriented systems such as ZETH and AZTEC [7,8], provide public verification over private transaction witnesses, but they mainly target asset ownership, values, or participant relationships rather than compliance with a provider-defined consent policy.

Hidden-policy access-control work reduces direct policy exposure by using encrypted policies, hidden-policy ABE variants, off-chain matching, or policy-holder components [13,18]. Functional encryption gives a more general cryptographic abstraction for revealing function outputs while hiding inputs [25], but it does not by itself yield publicly verifiable authorization evidence. Private-state blockchain systems, including Secret Network and Oasis/Ekiden, protect smart-contract state or execution through encrypted state and trusted execution environments [26,27]. These lines of work address adjacent forms of policy or state hiding, but TPS-ZKPI targets a more specific setting: hiding consent

policies on a public chain while retaining public verifiability of each authorization decision. Even where policies are hidden, existing designs may still leak policy-dependent artifacts through ciphertext structures, policy-update transactions, authorization workflows, or repeated interactions. Moreover, many target permissioned or off-chain settings, where enforcement artifacts are not globally visible as they are on public blockchains.

Privacy-preserving access-control and policy-evaluation mechanisms have been studied in credential-based and XACML/SAML settings [19], as well as in multi-party policy evaluation using homomorphic encryption and secure function evaluation [20]. These approaches support confidential authorization computation, but they are not primarily designed for settings where policy-evaluation artifacts—calldata, public inputs, emitted events, timing, and gas usage—are permanently and globally visible on a public blockchain. In addition, these approaches do not directly provide compact evidence that a smart contract can verify against a committed, provider-defined policy instance.

Reusable proving systems, including universal-setup SNARKs, composable proof systems, and zkVMs [21–23], improve maintainability by reducing the need for policy-specific circuits or verifier contracts. However, when deployed for public-chain consent enforcement, reusable proving alone does not guarantee policy privacy: policy-dependent program representations, public inputs, calldata layouts, logs, or gas profiles may still remain observable. This motivates TPS-ZKPI's use of a domain-specific reusable policy interpreter, which preserves proof reuse while exposing only a policy-independent public verification interface.

Public-chain metadata-leakage studies show that cryptographic privacy guarantees may be weakened by observable transaction-level artifacts such as timing and volume patterns [4]. Techniques such as batching, decoys, and traffic shaping can reduce some observable signals [24], but they are usually designed for payment privacy, anonymity sets, or transaction-linkability settings. They do not directly provide hidden-policy compliance verification or auditable consent enforcement. In contrast, TPS-ZKPI treats metadata leakage as part of the policy-privacy objective rather than as a separate transaction-level concern.

Existing approaches address verifiable consent recording, data confidentiality, transaction privacy, policy hiding, confidential policy evaluation, proof reuse, or metadata mitigation in isolation, whereas policy-private consent enforcement under public-chain observability requires the combination of policy confidentiality, metadata-leakage control, verifiable auditability, and a stable verification interface for evolving Boolean-based consent policies. Table 1 summarizes this positioning.

3. Problem and Threat Model

3.1. System and Trust Model

We consider a blockchain-based healthcare data-sharing system in which two types of users interact to share data: data providers, who provide protected resources and govern access to them through consent policies, and data requesters, who seek access to these resources subject to those policies. TPS-ZKPI mediates this interaction through three components: a Trusted Proof Service (TPS) operating off-chain, an on-chain access-control manager (ACM), and a data access layer. The provider defines a consent policy P for a protected resource on behalf of the data subject whose consent it encodes, and registers an on-chain commitment h to the encoded policy. The requester seeks access by submitting policy-relevant authorization evidence, such as attributes, credentials, and access context. The TPS constructs the private witness and generates a zero-knowledge proof of policy compliance. The ACM verifies the proof on-chain and records the authorization outcome, while the data access layer grants access according to the recorded decision.

TPS-ZKPI relies on the following assumptions. First, policies are provider-controlled: the provider is responsible for defining the applicable consent policy and committing the corresponding policy instance on-chain. Second, the TPS is trusted to preserve the confidentiality of policy-bound proving material and requester-submitted authorization evidence, and to follow the prescribed proof-generation workflow. Third, the commitment scheme is assumed to be hiding and binding, and the zero-knowledge proof system is assumed to satisfy completeness, soundness, and zero knowledge with respect to the implemented policy-compliance relation. Credential issuance, revocation, and real-world identity verification are treated as external functions.

Conceptually, the TPS is an independent proof service, distinct from the provider; this separation is what makes relocating trust meaningful, since it prevents the provider from being the single party that holds both the policy and the requester evidence. Possible instantiations of such an independent service include a third-party proof service, a TEE-backed proof service that makes the trust assumption hardware-attested, or MPC/collaborative SNARK proof generation in which no single party sees both policy material and requester evidence.

For implementation and evaluation simplicity, the current evaluation co-locates the TPS with the provider (a provider-operated TPS). This co-location concentrates trust at the provider side: a single party now holds both the policy and the requester evidence, so a compromised provider-operated TPS could construct witnesses from substituted attribute values or withhold proof generation from legitimate requesters. Two guarantees must be distinguished here. Authorization correctness is primarily enforced by the commitment and on-chain proof verification: a proof that does not satisfy the committed policy relation is rejected, largely independently of how the TPS is instantiated. Policy confidentiality, in contrast, is not cryptographically enforced against the TPS itself; it rests entirely on the trust assumption stated above. Our evaluation therefore assumes a TPS that follows the prescribed workflow and isolates the remaining question: what a public-chain observer can infer from the resulting public artifacts. Weakening the TPS trust assumption itself is orthogonal and is the role of the reduced-trust instantiations above.

3.2. Public-Chain Adversary

The primary adversary is a passive public-chain observer. The adversary can inspect smart-contract code and monitor public blockchain artifacts across multiple authorization sessions, including policy commitments, submitted proofs, public inputs, emitted events, calldata, timing, and gas usage. The adversary does not observe provider-to-TPS policy material, commitment-opening randomness, requester-submitted authorization evidence, credential witnesses, or TPS-side witness construction.

Each policy-enforcement instance corresponds to an authorization session, in which a requester seeks access to a protected resource under a committed policy. For each such session, the adversary observes a public view

$$view_{\mathsf{pub}} = (h, \pi, id_{\mathrm{req}}, id_{\mathrm{res}}, nonce, pp, meta), \tag{1}$$

where h is the on-chain commitment to the hidden policy, π is the zero-knowledge proof submitted for on-chain verification, id_{req}, id_{res}, and *nonce* are the public requester, resource, and session-binding values, *pp* denotes other fixed-format public parameters or public handles, and *meta* denotes transaction-level metadata exposed by the enforcement layer, such as calldata footprint, event structure, public-input layout, timing, and gas usage. The adversary's goal is to infer hidden information about the committed policy or the authorization interaction from this public view.

https://doi.org/10.3390/blockchains1010000

In addition to the public-chain observer, we treat the requester as untrusted with respect to policy confidentiality. The requester may initiate access requests, observe its own submitted evidence and authorization outcome, and inspect the public transcript. However, the requester does not receive the encoded policy, commitment-opening randomness, or policy-bound proving material, which remain within the provider-to-TPS proof-generation boundary.

Compromised TPS behavior, adaptive requester probing, and off-chain side channels are non-goals for the current model. The SNARK checks internal consistency of the witness it is given; it does not prove that the private attribute vector is the requester's real-world attribute set. Binding an authorization to id_{req}—in the current implementation, at the transaction level rather than inside the proof statement—ties the recorded outcome to an identifier and session context, but without an issuer-verification layer it does not by itself bind every private attribute value to an external source of truth. Because the TPS constructs the witness, a compromised TPS, or a TPS colluding with the provider, can substitute attribute values and still produce a verifying proof. Enforcing attribute-origin binding in-circuit would require the requester to reveal attributes in clear to the TPS for issuer-signature verification, which reintroduces the same confidentiality concession. Reconciling attribute-origin binding with attribute confidentiality under a single TPS is therefore a structural limitation, which the reduced-trust instantiations are intended to address.

3.3. Privacy Objectives

We operationalize policy privacy as three measurable, attack-oriented objectives that cover the information a public-chain observer could extract about a hidden policy: its semantic content, its identity relative to other policies, and its structural form. These correspond to Policy Content Hiding, Policy Indistinguishability, and Structure and Parameter Privacy, respectively.

Policy Content Hiding (PCH). PCH requires that public-chain artifacts should not reveal the semantic content of the hidden consent policy, such as data-use terms, disease categories, research purposes, institutional restrictions, or ethics-related requirements.

Policy Indistinguishability (PI). PI requires that different candidate policies should not become distinguishable from their public verification artifacts when they are compiled into the same fixed public interface. This captures whether two policies can be told apart from commitments, proofs, public parameters, or metadata even when their direct representations are hidden—that is, whether the identity of the governing policy can be narrowed down.

Structure and Parameter Privacy (SPP). SPP requires that public-chain artifacts should not reveal structural or parametric properties of the hidden policy, such as logical structure, nesting depth, predicate count, set size, or threshold-like parameters.

3.4. Problem Statement

Given a provider-defined consent policy P, requester authorization evidence, a globally observable public blockchain, and the stated TPS trust assumption, the problem is to enforce access to a protected healthcare resource while satisfying three requirements. First, authorization must be publicly verifiable: the ACM should be able to verify that the requester satisfies the committed policy without learning or executing the policy in plaintext. Second, policy-dependent information should remain hidden from public-chain observers, including policy content, policy identity, structural properties, requester evidence, and metadata-level enforcement fingerprints. Third, authorization outcomes should remain auditable, so that successful access decisions can be recorded and checked without exposing the hidden policy logic.

4. TPS-ZKPI Design

4.1. Overview

As shown in Figure 1, the TPS-ZKPI workflow binds a provider-committed hidden policy to requester-submitted authorization evidence through TPS-side proof generation and on-chain proof verification. The provider registers only a policy commitment on-chain and sends policy-bound proving material to the TPS off-chain. For each access request, the TPS constructs the private witness from the hidden policy material and requester evidence, generates a zero-knowledge proof of policy compliance, and submits a fixed-format proof statement for ACM verification. The ACM records the authorization outcome, which is then consumed by the data access layer.

This design separates confidentiality-sensitive proof generation from public verification. Policy material and requester evidence remain off-chain—policy material within the provider–TPS boundary, requester evidence between the requester and the TPS—while the blockchain verifies only a fixed-format proof statement against the provider's policy commitment, alongside session parameters validated by the ACM. Compared with a traditional requester-as-prover design in which the requester receives P_{enc} and the commitment-opening randomness, TPS-ZKPI closes that leak to the requester; the corresponding confidentiality failure now occurs only if the TPS trust boundary is violated.

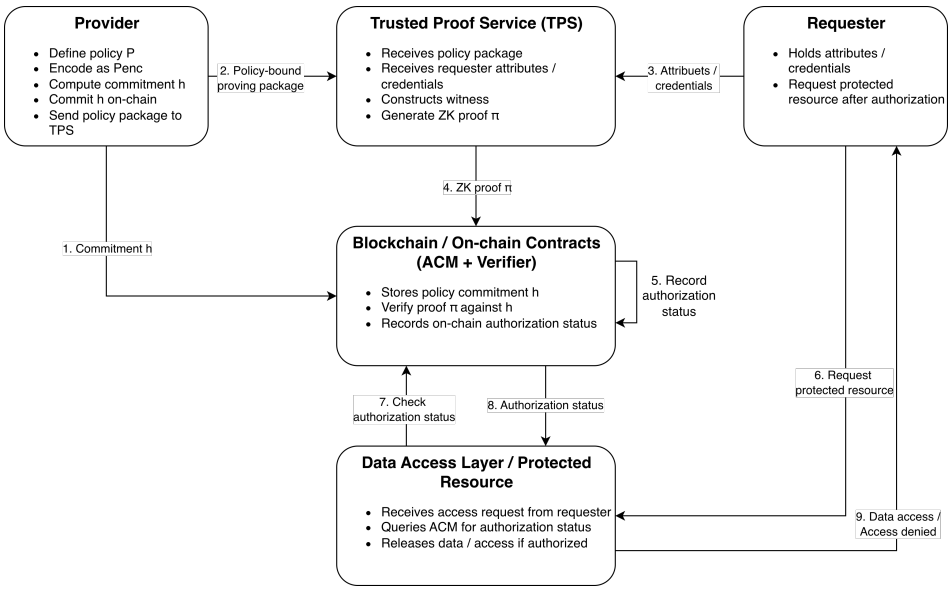


Figure 1. TPS-assisted policy-compliance workflow. The provider commits to the encoded policy on-chain and provisions proving material to the TPS (steps 1–2); the TPS constructs the witness from requester evidence and generates the proof (3–4); the ACM verifies the proof and records the outcome (5); the data access layer consults the recorded status to serve the requester (6–9).

4.2. Policy Representation and Interpretation

TPS-ZKPI represents heterogeneous Boolean-based consent policies in a fixed-length, circuit-friendly format. Let

$$X = \{0,1\}^N, \qquad B = \{0,1\}^M \tag{2}$$

denote the requester-attribute assignment space and the external-predicate assignment space, respectively. The full assignment space is

$$O = X \times B, \tag{3}$$

where $a \in X$ encodes requester attributes and $b \in B$ encodes externally attested predicate outcomes, such as credential validity, ontology-linked checks, or obligation-related conditions. TPS-ZKPI does not itself solve credential issuance, revocation, or external attestation; it consumes these outcomes and, where applicable, checks auxiliary witnesses inside the proof relation. In the current circuit implementation, issuer-signature verification is represented by a hash-based placeholder gadget (a Poseidon consistency check that provides no unforgeability), so attribute-origin binding is not enforced in-circuit. As a result, the current circuit does not prevent a requester from supplying fabricated attributes that satisfy the policy; enforcing attribute-origin binding requires a real in-circuit issuer-signature verifier, which we leave to future work. The resulting structural limitation is discussed in Section 3.

Consent policies are expressed as Boolean formulas over assignment bits:

$$P ::= atom \mid (P \wedge P) \mid (P \vee P) \mid \neg P, \qquad atom ::= x_i \mid y_j. \tag{4}$$

Here x_i selects requester-attribute bit a_i and y_j selects external-predicate bit b_j. Each policy is compiled into a Reverse Polish Notation (RPN) program over operand tokens and Boolean operator tokens. To support reusable verification, each program is padded to a fixed token length L:

$$P_{\text{enc}} = [t_1, \ldots, t_L], \tag{5}$$

together with an explicit program length $\ell \leq L$ carried as a private witness. The interpreter evaluates only the first ℓ tokens; padding positions beyond ℓ are inactive and leave the output unchanged. The implemented circuit uses $N = 6$, $M = 5$, and $L = \mathsf{DEPTH} = 20$. We denote the set of length-L programs by Prog_L.

The reusable policy interpreter is a zero-knowledge circuit

$$C : \mathsf{Prog}_L \times \{0, \ldots, L\} \times O \to \{0, 1\}. \tag{6}$$

Given an encoded policy, its program length, and operand values, the interpreter evaluates the RPN program using deterministic stack semantics and enforces well-formedness constraints inside the circuit. The circuit outputs 1 only if the requester evidence satisfies the encoded policy. Well-formedness is enforced as hard constraints: for a program that violates the stack discipline, no satisfying witness exists and no proof can be generated. An output of 0 therefore indicates unsatisfied evidence for a well-formed program. The proved acceptance relation is the asserted case $C(P_{\text{enc}}, \ell, (a, b)) = 1$.

This design avoids policy-specific circuits and verifier contracts while supporting policy evolution through different fixed-length policy programs.

4.3. Commitment Binding and Proof Generation

To bind each proof to a provider-defined hidden policy, the provider samples commitment randomness r uniformly from the scalar field and computes

$$h = \mathsf{Com}(P_{\text{enc}}; r) = \mathsf{Poseidon}(P_{\text{enc}} \parallel r), \tag{7}$$

where h is stored on-chain as the public handle of the hidden policy. Under the collision resistance of Poseidon, the commitment binds future proofs to the committed token array P_{enc}. The program length ℓ is not part of the commitment preimage: supplying the length recorded at encoding time is part of the prescribed TPS workflow (Section 3.1), and a TPS that deviates from the workflow could evaluate a stack-consistent prefix of the committed array. Binding ℓ into the commitment is a straightforward hardening that we leave to future work. Hiding is an explicit commitment assumption (Section 3.1) that relies on

high-entropy r and the fixed-length encoding of P_{enc}, which keeps the sponge input unambiguous.

For an access request, the TPS constructs the private witness

$$w = (P_{\text{enc}}, \ell, a, b, r, \omega), \tag{8}$$

where P_{enc} is the encoded policy, ℓ is its program length, a denotes requester attributes, b denotes external predicate outcomes, r is the commitment randomness, and ω denotes auxiliary witnesses for credential- or predicate-dependent checks. The public statement contains the asserted authorization output, the policy commitment h, and a fixed-format parameter commitment pp, which binds per-predicate parameters without exposing them in calldata. The requester and resource identifiers and a session nonce are carried as transaction-level parameters that the ACM validates.

For the compiled circuit, the Groth16 [28] setup produces the common reference string as a proving key and a verification key, once for the shared circuit:

$$(pk, vk) \leftarrow \mathsf{Setup}(C). \tag{9}$$

The TPS generates a proof

$$\pi \leftarrow \mathsf{Prove}\big(pk, w; (1, h, pp)\big). \tag{10}$$

The proof certifies the conjunction that $C(P_{\text{enc}}, \ell, (a, b)) = 1$, the hidden policy encoding is consistent with the on-chain commitment h, and required external-predicate checks are internally consistent with respect to the supplied parameters and placeholder gadgets. The proof statement is not bound to the requester, resource, or session context: the ACM validates these as transaction-level parameters, and nonce single-use prevents reuse of the same session parameters only, so replay of a captured proof with fresh parameters by an active submitter is not prevented and lies outside the passive threat model of Section 3. Binding the session context into the public statement is a standard hardening that we leave to future work.

The ACM verifies π on-chain against vk and the public statement, and records the outcome of each request: a positive authorization outcome requires both a valid proof and an asserted output of 1; otherwise the request is recorded as a denial. The policy encoding, commitment randomness, requester attributes, credential witnesses, and auxiliary proof material are not posted on-chain.

4.4. Transcript Normalization

Zero-knowledge proofs hide private witness values, but surrounding blockchain artifacts may still leak policy-dependent information. TPS-ZKPI therefore normalizes the public transcript so that different policies induce fixed or tightly bounded observable profiles. Table 2 summarizes the mechanisms.

Table 2. Transcript-normalization mechanisms in TPS-ZKPI.

Artifact	Normalization mechanism
Calldata	Fixed verification interface and fixed-size proof/public-input encoding.
Logs	Fixed event structure with constant topic and payload layout.
Public parameters	Fixed-format handles instead of policy artifacts or credential witnesses.
Gas usage	Policy-independent verifier logic and randomized gas padding toward fixed targets.

These mechanisms do not eliminate all public observability. Rather, they reduce policy-dependent variation in calldata, logs, public parameters, and gas-related behavior that could otherwise serve as a fingerprint for the metadata-only adversary defined in Section 3. TPS-ZKPI does not flatten all residual channels: timing between transactions,

transaction ordering, mempool or broadcast patterns, and off-chain TPS communication remain outside the normalized public transcript.

5. Privacy Evaluation

We evaluate the three privacy objectives of our approach—Policy Content Hiding, Policy Indistinguishability, and Structure & Parameter Privacy—against a passive on-chain observer (Section 5.1). The primary evidence is a supervised, multi-seed attack evaluation with policy-disjoint splits and permutation tests (Section 5.2); unsupervised clustering provides a label-free cross-check on the same executions. All three objectives pass the supervised criterion, and the clustering attack finds no natural grouping by hidden labels.

5.1. Adversary and observables

We evaluate against the passive public-chain observer defined in Section 3: an adversary with unrestricted, perpetual read access to the ledger, who sees every transaction and event our approach emits but never the plaintext policy or the witness.

Concretely, for each policy execution (a commit transaction followed by an access transaction) the adversary observes the following on-chain features:

- **Gas:** `commitGasUsed`, `accessGasUsed`.
- **Calldata length:** `commitCalldataLength`, `accessCalldataLength`.
- **Proof size:** `proofSize`.
- **Event logs:** `commitLogsCount`, `commitLogsSize`, `accessLogsCount`, `accessLogsSize`.

By design, calldata length, proof size, and log counts/sizes are content-independent (constant across policies), so any residual signal can only flow through the gas features in the modeled public transcript. The effective feature set the attacker can exploit therefore reduces to the two gas measurements (`commitGasUsed`, `accessGasUsed`); the remaining observables are retained in the pipeline but carry no policy-dependent variation. The defenses (commitment-only interface, randomized access-gas padding) target exactly this channel. We do not model side channels such as block timing, transaction ordering, mempool or broadcast patterns, or off-chain TPS communication; these, together with the non-goals stated in Section 3, remain outside this evaluation model.

We consider three increasingly fine-grained attacker tasks, one per privacy objective: (i) recover the policy's *content* (PCH, Section 5.3); (ii) tell two *semantically related* policies apart (PI, Section 5.4); and (iii) recover the policy's *structure or parameter magnitude* (SPP, Section 5.5).

5.2. Attack methodology

We evaluate each privacy objective with a primary supervised attack and a complementary unsupervised cross-check. The *supervised* pipeline asks whether a trained classifier can recover a hidden label from the observables; this is the main privacy verdict because it gives the adversary labels and therefore more power than a purely exploratory analysis. The *unsupervised* pipeline asks whether the observables cluster along the hidden label without any supervision, providing a label-free sanity check on the same executions. Both pipelines run on the same fixed-circuit, commitment-only, access-gas-padded *Polygon Amoy* dataset: the supervised numbers reported in this paper are read from `experiments/multiseed_results/polygonAmoy/`, and the clustering reads the same executions exported to `python/data/polygonAmoy/`. Per-task sample sizes vary and are listed in the result tables (e.g. 2005 DUO executions; 133 balanced 30-vs-30 PI pairs). The dataset, attack code, and verdict files are released as an accompanying artifact (anonymized for re-

view); the paths above are relative to its root, and provenance for every table and figure is listed in its `README.md`.

5.2.1. Supervised attacks

For every task we train a linear and a non-linear classifier (logistic regression, LR; random forest, RF) and report the score used by the unified verdict for that objective. Each task is evaluated over **30 random seeds** using a **policy-disjoint train/test split**: the policies used to train the attacker never appear in the test set, so a high score cannot come from memorizing individual policies. For each seed we run a label-permutation test and record whether the AUC is significant at α=0.05.

The headline metrics are the AUC, its distance from chance averaged over seeds, $\text{mean}_s\,|\text{AUC}_s - 0.5|$ (reported as the AUC gap), and the permutation p-value averaged over seeds (p_{perm}). Because the gap averages per-seed absolute deviations, it is generally larger than $|\text{AUC}_{\text{mean}} - 0.5|$ computed from the mean AUC. The mean permutation p-value p_{perm} is reported as a diagnostic only; gating uses the significant-seed fraction—the fraction of seeds whose per-seed test rejects at α=0.05—defined below, not this pooled p_{perm}. This AUC gap is an empirical, sample-estimated diagnostic, not the advantage of a formal cryptographic distinguisher and not a proven security bound. The unified verdict is:

> **FAIL** iff $\text{AUC}_{\text{mean}} > 0.55$ **and** the significant-seed fraction is ≥ 0.5 (over 30 policy-disjoint seeds); **PASS** otherwise.

Both legs of this *double criterion* are required: high classification power that is not statistically reproducible across seeds (or reproducible significance with chance-level AUC) does not constitute a leak.

Tasks whose test split contains fewer than 20 executions (median over the 30 seeded splits) are *underpowered*—reported but excluded from gating, so a small task's sampling noise cannot decide the verdict. Every task gates on LR and RF independently and fails if either clears the double criterion; the result tables report the stronger (higher-AUC) classifier for each task. For SPP, LR over-separates on the near-constant features (see below) and yields a degenerate AUC, so the operative signal is the RF score—the fraction of trees voting for the class—which remains continuous.

As established in Section 5.1, the transcript normalization leaves gas as the only policy-dependent channel; the LR/RF feature set is therefore the two gas measurements, which is why LR saturates on the otherwise near-constant SPP inputs. To distinguish a genuine defense from a weak attacker, we pair the near-chance main results with the gas-normalization positive control in Section 5.8: the same features, splits, and classifiers recover signal on the un-padded gas transcript and collapse after padding.

5.2.2. Unsupervised clustering attacks

The clustering attacker drops the labels entirely and asks whether the gas features *naturally* group along the hidden property. We run K-Means (with K set to the number of classes, or K=2 for policy pairs) on the on-chain gas features, and score the recovered clusters against the true labels with the Adjusted Rand Index (ARI) and Normalized Mutual Information (NMI). Values near 0 mean the clusters carry no information about the hidden label; values near 1 mean full leakage.

PCH clusters all executions globally (no per-layer splitting), so the large-sample ARI/NMI are read directly.

For the PI pairs, which are much smaller, we apply two corrections in sequence—first rebalancing the pairs, then debiasing the residual small-sample inflation that survives rebalancing. **Rebalancing the pairs.** The naive PI pair construction produced severely im-

balanced pairs (one policy with 1 execution against another with up to 30), where K-Means cannot partition the two policies and ARI/NMI ≈ 0 is an artifact rather than evidence of privacy. We therefore rebuild the PI pairs from policies with ≥ 30 executions into balanced 30-vs-30 contrasts before clustering. **Debiasing residual inflation.** Rebalancing removes the imbalance artifact, but each side of a balanced pair still holds only 30 executions. At that scale the null simulation in Section 5.7 shows that finite-sample effects can still raise NMI above zero while ARI stays at chance, so here ARI is already conservatively near zero and NMI is the more sensitive—but biased—indicator. To debias it we add a *permutation baseline*: we shuffle the pair labels 200 times and recompute the clustering NMI, giving the NMI distribution under zero true signal. The debiased NMI is the observed value minus this baseline, and the empirical p-value p_{NMI} is the fraction of permutations whose NMI meets or exceeds the observed; the clustering cross-check flags a pair only if its debiased NMI is positive *and* significant ($p_{\text{NMI}} < 0.05$). The PI debiasing averages each observed NMI over 20 K-Means seeds against a 200-permutation baseline over 133 balanced 30-vs-30 pairs.

Table 3. Headline privacy results on the Polygon Amoy dataset. The supervised attacker uses 30 policy-disjoint seeds and a permutation test. A task passes unless both $\text{AUC}_{\text{mean}} > 0.55$ and at least 50% of seeds are significant.

Property	Hidden target	Headline supervised result	Verdict
PCH	DUO terms and ICD-10 chapters	16 content-recovery tasks pass; DUO AUCs 0.490–0.527, ICD AUCs 0.458–0.573	✓
PI	Related policy-pair identity	Overall AUC 0.516 ± 0.030, $p_{\text{perm}} = 0.367$, 10% significant seeds	✓
SPP	Structure, predicate, parameter, and nesting-depth buckets	28 pairwise contrasts pass; AUCs 0.421–0.530, max 20% significant seeds	✓

5.3. Policy Content Hiding (PCH)

Property. PCH requires that the on-chain observer cannot recover the *content* of a policy—its DUO data-use terms or the ICD-10 disease codes it references—better than chance.

Scope of the labels. We restrict the generated policies to labels with enough support for a statistically powered one-vs-rest attack: six DUO data-use terms (GR, DS, RS, POA, GS, CC; smallest class n=30) and disease codes aggregated to the ten ICD-10 chapters. The full DUO has 23 data-use terms and ICD-10 has tens of thousands of leaf codes; generating and executing enough policies for every term to reach adequate statistical power would inflate the experiment beyond what is feasible on-chain. This category-level granularity is also the right one for the privacy question—the observer cares whether the *category* of permitted use or disease leaks, not which leaf code is used—and it is a conservative choice: attacks on coarser, better-supported labels are *easier* than on rare leaf terms, so passing here does not understate the leak. The defenses in question are the commitment-only interface and gas padding, which are content-agnostic and independent of which terms a policy carries.

Supervised attack. We treat each of the six DUO terms (GR, DS, RS, POA, GS, CC) as a one-vs-rest binary recovery task and run the multi-seed pipeline of Section 5.2. Table 4 reports the per-term verdicts: every DUO task has $\text{AUC}_{\text{mean}} \in [0.490, 0.527]$ and a significant-seed fraction of at most 13%, so none approaches either leg of the failure criterion. The same pipeline applied to the ten ICD-10 chapters (one-vs-rest over the ICD-bearing rows only,

median test n=300 per chapter; Table 5) passes all ten. The single highest AUC is ch6's $\text{AUC}_{\text{mean}} = 0.573 \pm 0.061$ with 17% significant seeds; it clears the AUC leg ($0.573 > 0.55$) but not the reproducibility leg ($17\% < 50\%$), so it is a boundary case rather than a stable channel. We report such cases rather than suppress them.

Table 4. Policy Content Hiding: per-term supervised attack over 30 policy-disjoint seeds. Each DUO term is a one-vs-rest binary task. *%sig* is the fraction of seeds whose permutation test rejects at α=0.05. All six tasks pass the unified criterion.

Term	AUC (mean ± std)	AUC gap (mean ± std)	p_{perm}	%sig	med n
DUO GR	0.497 ± 0.024	0.020 ± 0.014	0.535	0%	613
DUO DS	0.490 ± 0.021	0.019 ± 0.014	0.624	3%	613
DUO RS	0.527 ± 0.019	0.029 ± 0.017	0.191	13%	613
DUO POA	0.493 ± 0.023	0.019 ± 0.016	0.579	0%	613
DUO GS	0.521 ± 0.018	0.023 ± 0.016	0.251	13%	613
DUO CC	0.501 ± 0.018	0.013 ± 0.012	0.479	0%	613

Table 5. Policy Content Hiding: per-chapter ICD-10 supervised attack over 30 policy-disjoint seeds (one-vs-rest, ICD-bearing rows only; median test $n = 300$). The highest value is ch6 (AUC 0.573, %sig 17%), but it clears neither the AUC nor the reproducibility leg of the criterion, so all ten chapters pass.

Chapter	AUC (mean ± std)	AUC gap (mean ± std)	p_{perm}	%sig	med n
ICD ch0	0.488 ± 0.068	0.051 ± 0.047	0.536	0%	300
ICD ch1	0.490 ± 0.050	0.042 ± 0.030	0.560	0%	300
ICD ch2	0.513 ± 0.051	0.044 ± 0.029	0.424	7%	300
ICD ch3	0.524 ± 0.042	0.040 ± 0.027	0.358	0%	300
ICD ch4	0.547 ± 0.055	0.058 ± 0.044	0.278	17%	300
ICD ch5	0.458 ± 0.060	0.056 ± 0.048	0.700	0%	300
ICD ch6	0.573 ± 0.061	0.083 ± 0.046	0.206	17%	300
ICD ch7	0.490 ± 0.048	0.039 ± 0.029	0.595	0%	300
ICD ch8	0.537 ± 0.055	0.048 ± 0.046	0.327	10%	300
ICD ch9	0.524 ± 0.057	0.048 ± 0.039	0.395	7%	300

5.4. Policy Indistinguishability (PI)

Property. PI strengthens PCH: even when two policies are *semantically related*, the observer must not tell which one was executed—formally, $\Pr[\hat{b} = b] \approx \frac{1}{2}$. We test four pair archetypes, separated by semantic similarity and by whether structure or execution protections differ: `semantic_equivalent` (near-identical semantics, similarity ≥ 0.999, but different structure), `structural_variant` (the same, plus differing execution protections), `weak_equivalent` (≥ 0.95 semantic overlap), and `controlled_difference` (similarity < 0.95, the least similar pairs by construction; a diagnostic control that does not gate the verdict). Semantic similarity here is a fixed heuristic score over policy semantics—the Jaccard overlap of DUO terms combined with agreement of the ICD-10, OBI, and other scope fields—that returns 1 when two policies share an identical normalized logic string. The ≥ 0.999 threshold therefore selects logically identical policies and ≥ 0.95 their close approximations; the exact component weights are given in the released artifact.

Supervised attack. The attacker's task is to decide, from the on-chain features of a single execution, which policy of the pair produced it. We train a logistic-regression and a random-forest classifier and, per archetype, report the higher-AUC one, following the convention of Section 5.2; the random forest leads on every archetype except the non-gating `controlled_difference` control. We evaluate this single-execution attacker over 30 policy-disjoint seeds (Table 6). The overall AUC is 0.516 ± 0.030 with only 10% of

seeds significant ($p_{\text{perm}} = 0.367$). All three gating archetypes—`semantic_equivalent`, `structural_variant`, and `weak_equivalent`—remain within noise of chance. `controlled_difference` is reported as a diagnostic control but does not gate the PI verdict.

Table 6. Policy Indistinguishability: single-sample distinguisher (Level I) over 30 policy-disjoint seeds, by policy-pair archetype. `controlled_difference` is reported as a diagnostic control and excluded from the PI verdict.

Pair archetype	AUC (mean ± std)	AUC gap (mean ± std)	p_{perm}	%sig	med n
overall	0.516 ± 0.030	0.026 ± 0.022	0.367	10%	270
semantic_equivalent	0.511 ± 0.082	0.070 ± 0.045	0.456	13%	71
structural_variant	0.524 ± 0.071	0.059 ± 0.046	0.407	0%	40
weak_equivalent	0.494 ± 0.085	0.069 ± 0.051	0.529	7%	54.5
controlled_difference †	0.510 ± 0.076	0.065 ± 0.041	0.452	3%	68

† Diagnostic control; does not gate the PI verdict.

5.5. Structure & Parameter Privacy (SPP)

Property. SPP requires that neither the *shape* of a policy (logical structure, nesting depth, predicate coverage) nor the *magnitude* of its parameters (whitelist/set sizes) leaks to the observer. The supervised attack organizes the test along four annotation axes—logical structure type (`structureType`), predicate count (`predicateCombo`), parameter magnitude (`paramType`), and nesting depth (`nestingDepth`)—and attacks each pair of buckets within an axis. `structureType` has five buckets: `trivial` (a single predicate with no boolean connective, e.g. policy logic `"GR"`), `and_only`, `or_only`, `and_or_mixed`, and `negation_heavy`. `predicateCombo` buckets policies by predicate-namespace count into `none` (0), `single` (1), `few` (2–3), and `many` (≥ 4); `paramType` buckets by whitelist size into `none` (no whitelist), `small` (1–4), `medium` (5–16), and `large` (≥ 17); `nestingDepth` buckets by structural nesting into `flat`, `shallow`, `medium`, and `deep`. Contrasting every within-axis bucket pair gives $10 + 6 + 6 + 6 = 28$ contrasts.

Supervised attack. Table 7 reports all 28 pairwise contrasts over 30 policy-disjoint seeds, with the per-contrast AUC taken from the higher-scoring of the two classifiers following the convention of Section 5.2. Every contrast has $\text{AUC}_{\text{mean}} \in [0.421, 0.530]$ and a significant-seed fraction at or below 20%, so all 28 pass the AUC-plus-permutation criterion and SPP passes overall. Reporting AUC rather than an accuracy-style score keeps the imbalanced contrasts (e.g. the small `none` buckets) from registering apparent gains that are only majority-class prediction, as noted in Section 5.2. Section 5.8 provides the corresponding positive control: when gas padding is removed, the same SPP attacker recovers structural and parameter-magnitude signal, and that signal collapses under the full normalization.

Table 7. Structure & Parameter Privacy: 28 pairwise contrasts across four annotation axes, each over 30 policy-disjoint seeds. AUC is the higher-scoring of logistic regression and random forest per contrast (the stronger-attacker leg used for gating). Every contrast satisfies $\text{AUC}_{\text{mean}} \leq 0.55$ *and* %sig $< 50\%$.

Contrast	AUC (mean ± std)	AUC gap (mean ± std)	p_{perm}	%sig	med n
structureType					
trivial / or_only	0.498 ± 0.043	0.036 ± 0.024	0.519	3%	154
trivial / and_only	0.479 ± 0.040	0.036 ± 0.028	0.607	0%	78
trivial / negation_heavy	0.516 ± 0.031	0.028 ± 0.021	0.399	3%	139
trivial / and_or_mixed	0.511 ± 0.039	0.035 ± 0.022	0.425	0%	107
and_only / or_only	0.472 ± 0.032	0.034 ± 0.026	0.666	0%	139
or_only / negation_heavy	0.530 ± 0.033	0.034 ± 0.029	0.295	20%	199
or_only / and_or_mixed	0.489 ± 0.039	0.034 ± 0.021	0.573	0%	171
and_only / negation_heavy	0.485 ± 0.050	0.045 ± 0.027	0.575	0%	125
and_only / and_or_mixed	0.492 ± 0.049	0.040 ± 0.030	0.553	0%	93
negation_heavy / and_or_mixed	0.516 ± 0.036	0.034 ± 0.020	0.392	0%	154
predicateCombo					
none / single	0.461 ± 0.192	0.171 ± 0.095	0.542	4%	74
none / few	0.499 ± 0.202	0.157 ± 0.127	0.508	7%	215
none / many	0.476 ± 0.211	0.167 ± 0.132	0.508	0%	59
single / few	0.496 ± 0.033	0.027 ± 0.019	0.533	0%	284
single / many	0.490 ± 0.045	0.035 ± 0.031	0.563	3%	128
few / many	0.478 ± 0.035	0.033 ± 0.026	0.643	0%	268
paramType					
none / small	0.444 ± 0.205	0.159 ± 0.140	0.571	3%	66
none / medium	0.507 ± 0.262	0.212 ± 0.154	0.482	15%	203
none / large	0.421 ± 0.203	0.176 ± 0.128	0.606	4%	77
small / medium	0.510 ± 0.038	0.032 ± 0.022	0.423	3%	263
small / large	0.527 ± 0.036	0.037 ± 0.027	0.336	3%	139
medium / large	0.499 ± 0.031	0.025 ± 0.017	0.510	3%	277
nestingDepth					
flat / shallow	0.501 ± 0.048	0.035 ± 0.033	0.471	3%	227
flat / medium	0.513 ± 0.051	0.043 ± 0.031	0.430	3%	104
flat / deep	0.491 ± 0.046	0.039 ± 0.026	0.543	0%	103
shallow / medium	0.493 ± 0.047	0.037 ± 0.031	0.533	3%	239
shallow / deep	0.485 ± 0.043	0.036 ± 0.028	0.597	3%	236
medium / deep	0.497 ± 0.049	0.040 ± 0.029	0.508	0%	115

5.6. Unsupervised clustering: a label-free cross-check

The supervised attacks (Sections 5.3–5.5) assume an adversary who can train on labeled executions. A weaker but assumption-free attacker simply asks whether the on-chain gas features *cluster* along the hidden property with no supervision at all. Table 8 consolidates this attack across all three objectives: K-Means recovers essentially nothing, with ARI within ±0.002 and NMI below 0.02 for every DUO, PI, and SPP target. NMI values are interpreted against the null finite-sample simulation in Section 5.7, which shows that the slightly higher ICD-10 NMI is consistent with small-sample inflation rather than recoverable signal. The unsupervised attacker agrees with the supervised verdict—privacy holds—as a second, label-free attack family on the same dataset (Figure 2).

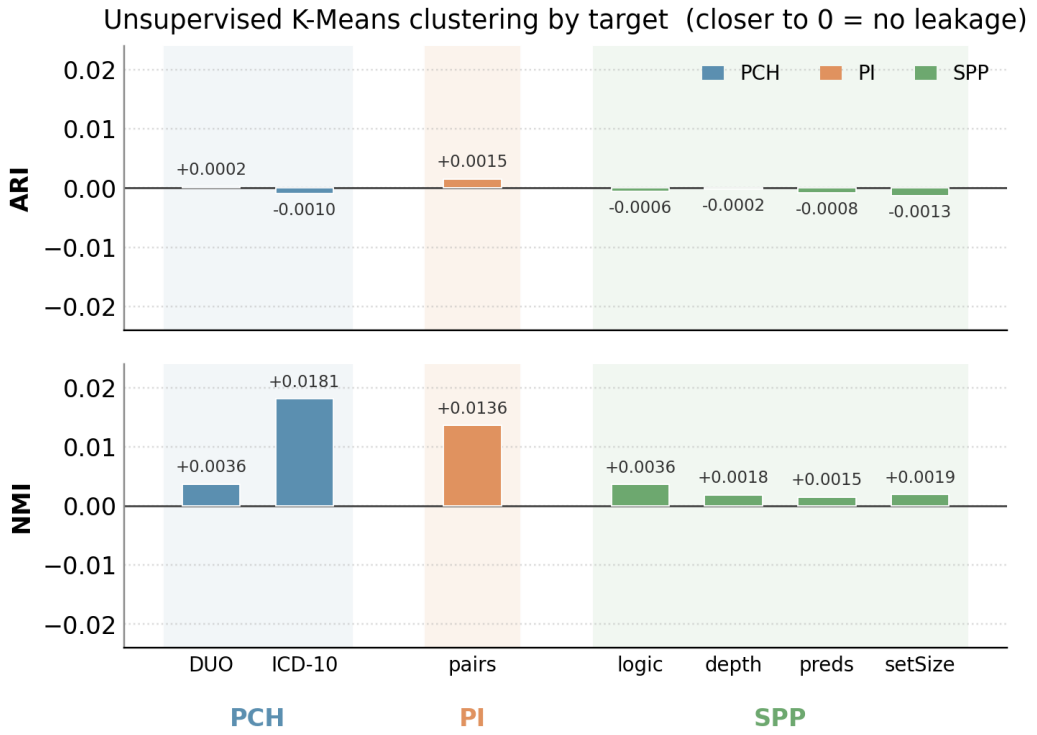


Figure 2. Unsupervised K-Means clustering across all three objectives on a common axis: ARI (top) and NMI (bottom) for every PCH, PI, and SPP target. Every bar sits at the zero line—the natural gas clusters carry no information about the hidden label. The SPP bar labels use the raw clustering fields, which map to the supervised axes of Section 5.5 as `logicStructure`=`structureType`, `predicateCount`=`predicateCombo`, and `setSize`=`paramType`; `nestingDepth` is a supervised axis under its own name. NMI is read against the null finite-sample simulation in Section 5.7.

Removing sample-size confounds. The PI clustering inputs are rebalanced into 30-vs-30 contrasts and permutation-debiased as described in Section 5.2, so the near-zero ARI/NMI is not a degenerate-measurement artifact. The conclusion matches the supervised PI verdict (Section 5.4), and the ablation (Section 5.8) confirms the clustering device itself is live: significance appears on the un-padded gas transcript and disappears after normalization.

Table 8. Unsupervised clustering attack (K-Means, K=number of classes / K=2 for pairs) on the on-chain gas features. ARI and NMI near 0 mean the natural gas clusters carry no information about the hidden label; NMI is interpreted against the null simulation in Section 5.7. PCH clusters all executions globally (no layering).

Property	Target	n	#cls.	ARI	NMI
PCH	DUO terms	2005	6	0.0002	0.0036
PCH	ICD-10 chapters	920	10	−0.0010	0.0181
PI	policy pairs (30v30)	133	2	0.0015	0.0136
SPP	`structureType`	1141	5	−0.0006	0.0036
SPP	`predicateCombo`	1141	4	−0.0008	0.0015
SPP	`paramType`	1141	4	−0.0013	0.0019
SPP	`nestingDepth`	1141	4	−0.0002	0.0018

5.7. Sample-size sensitivity of NMI

The clustering cross-check (Section 5.6) treats ARI as the primary conservative indicator because NMI can take moderately high values under small samples. To justify that choice, we quantify how *finite-sample effects* alone can inflate NMI even when there is *no* discriminative signal, using an idealized null in which all classes are statistically indistinguishable.

Null hypothesis. We sample every class from the *same* distribution, $x_i \sim \mathcal{N}(0, I_d)$ for all classes, where d is the synthetic feature dimension and I_d is the d-dimensional identity covariance. Since no class carries class-specific information, a clustering algorithm should not recover class membership, and both NMI and ARI should concentrate around 0 as the sample size grows.

Simulation. For each configuration we run $T = 1000$ independent trials. In each trial we (i) generate C classes with n i.i.d. samples per class from $\mathcal{N}(0, I_d)$, assigning each sample a class label by construction order (these labels are independent of the sample values, since all classes share one distribution), (ii) apply K-Means with $K = C$ to the pooled data, and (iii) score the predicted assignments against these assigned class labels with NMI and ARI. We sweep n while holding C fixed, and report the trial means $\overline{\text{NMI}}$ and $\overline{\text{ARI}}$. We consider a **PI-like** binary structure ($C = 2$, $n \in \{3, 10, 50, 100\}$) and an **ICD10-like** multi-class structure ($C = 5$, $n \in \{3, 10, 100\}$).

Results. Table 9 shows that, although all classes are indistinguishable by construction, **NMI is noticeably positive at very small n but collapses toward zero as n grows**, whereas **ARI stays near zero throughout**. For the binary structure, $\overline{\text{NMI}}$ falls from 0.1808 at n=3 (N=6) to 0.0404 at n=10, and to 0.0066/0.0038 at n=50/100, while $\overline{\text{ARI}}$ stays at -0.0190, -0.0020, -0.0011, 0.0002. For the multi-class structure the same trend holds: $\overline{\text{NMI}}$ goes from 0.4168 (n=3) to 0.1249 (n=10) to 0.0105 (n=100), with $\overline{\text{ARI}}$ near zero (0.0005, 0.0018, -0.0000). Hence moderately high NMI in small-sample clustering should not be read as actionable leakage, and ARI is the more conservative indicator of practical recoverability in our unsupervised evaluation.

Table 9. Sample-size sensitivity of NMI and ARI under the null hypothesis where all classes are i.i.d. sampled from $\mathcal{N}(0, I_d)$ (T=1000 trials per row).

Structure	n (per class)	C	N	$\overline{\text{NMI}}$	$\overline{\text{ARI}}$
PI-like	3	2	6	0.1808	−0.0190
PI-like	10	2	20	0.0404	−0.0020
PI-like	50	2	100	0.0066	−0.0011
PI-like	100	2	200	0.0038	0.0002
ICD10-like	3	5	15	0.4168	0.0005
ICD10-like	10	5	50	0.1249	0.0018
ICD10-like	100	5	500	0.0105	−0.0000

5.8. Ablation: gas-normalization positive control

The main results show that the full mechanism hides content, policy identity, and structure/parameters. The ablation asks *why*: how much of the residual attack surface is removed by randomized access-gas padding after the fixed circuit and commitment-only interface have already eliminated calldata, proof-size, and event-log channels.

We compare two aligned protection profiles on the same selected policy set. **B1** uses the fixed circuit, commitment-only interface, and TPS execution profile without commit/access gas padding. **B2** is the full mechanism used in the main evaluation, with randomized access-gas padding. This is the positive control for the gas channel: calldata, proof size, and event-log shape are already fixed, so B1 is an un-padded gas-transcript control rather than a run with every normalization layer removed. The same features, splits, and classifiers produce well-above-chance AUCs on B1 when padding is absent, while B2 returns the attacker toward chance. Thus the main privacy claim rests on a real ablation contrast rather than on a synthetic label derived from an input feature. The paired leakage metric is

$$\Delta_{\text{leak}} = |\text{AUC}_{\text{B1}} - 0.5| - |\text{AUC}_{\text{B2}} - 0.5|.$$

Positive values mean padding moved the attacker closer to chance, and we bound each Δ_{leak} with a 500-iteration bootstrap 95% confidence interval. Table 10 is intentionally separated from the main privacy verdicts: the main verdicts answer whether the full mechanism is private; this ablation attributes that privacy to a specific defense layer and reports its gas cost.

Padding removes otherwise-recoverable signal. Figure 3 reports the *full* set of supervised contrasts: each point places a contrast at its unpadded deviation from chance $|\text{AUC}_{\text{B1}} - 0.5|$ against its padded deviation $|\text{AUC}_{\text{B2}} - 0.5|$, so points below the diagonal are contrasts where padding moved the attacker back toward chance. The distribution is asymmetric in exactly the way an effective defense predicts. Every contrast on which B1 carries a sizable signal ($|\text{AUC}_{\text{B1}} - 0.5| > 0.15$) collapses to near the padded axis under B2. The two strongest SPP contrasts illustrate this: `nestingDepth flat/medium` falls from AUC 0.85 to 0.49, and `structureType trivial/and_or_mixed` from 0.85 to 0.50, each with a bootstrap Δ_{leak} whose 95% CI excludes zero (a statistically significant reduction). Across the 49 random-forest contrasts the median unpadded deviation of 0.103 drops to 0.024 under padding, and the per-family median Δ_{leak} is $+0.126$ (SPP) and $+0.052$ (PI). The clustering attacker shows the same pattern on a second, label-free attack family: PI pairwise clustering reaches debiased significance on 68% of pairs under B1 (mean ARI 0.50) versus 5% under B2 (mean ARI 0.0015), and SPP logic-structure clustering drops from ARI 0.043 (B1) to -0.001 (B2). This attributes the gas-channel protection reported in Sections 5.3–5.6 to randomized access-gas padding, rather than to weak attacks or insufficient sample size.

The effect is conditional, and we report it as such. Padding reduces leakage wherever a recoverable gas-channel signal exists and is otherwise inert: the 7 random-forest contrasts with no detectable effect (Δ_{leak} CI spanning zero) sit in the lower-left of Figure 3, where B1 is already near chance so there is little to remove. This is most visible for PCH, whose gas-channel signal is weak even unpadded (per-family median $\Delta_{\text{leak}} = -0.012$); padding neither helps nor hurts there. This does not mean PCH is free of leakage—a few DUO contrasts do carry a small B1 signal that padding removes (e.g. `DUO POA`, AUC $0.62 \rightarrow 0.49$)—but PCH content hiding rests mainly on the commitment-only interface and the content-independent transcript normalization rather than on gas padding, so the gas-padding ablation has little to attribute to it. Six random-forest contrasts have a Δ_{leak} CI on the negative side; all are rare ICD-10 chapters on which B1 already sits near chance (AUC 0.48–0.54), so the negative value reflects finite-sample movement of an already-uninformative attacker rather than padding creating leakage, and none of these tasks is flagged as a leak by the multi-seed verdict. These per-contrast counts are descriptive, not multiplicity-corrected; the causal claim rests on the direction and magnitude of the shift where a signal is present, corroborated by the independent clustering attacker. The logistic-regression panel (shown for robustness only, since it over-separates on the near-constant execution features) exhibits the same below-diagonal shift.

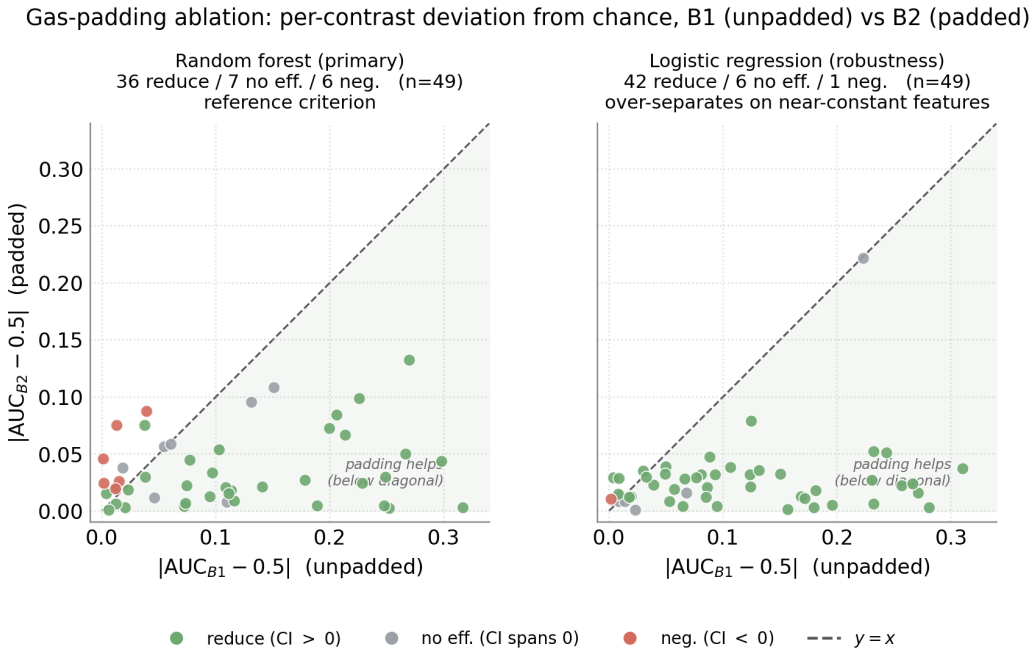


Figure 3. Gas-padding ablation over *all* supervised contrasts. Each point is one contrast at its unpadded deviation from chance $|\mathrm{AUC}_{\mathrm{B1}} - 0.5|$ (x) versus its padded deviation $|\mathrm{AUC}_{\mathrm{B2}} - 0.5|$ (y); points below the $y = x$ diagonal are cases where randomized access-gas padding moved the attacker back toward chance. Color encodes the sign of the bootstrap 95% CI of Δ_{leak}: reduce (CI> 0), no effect (CI spans 0), negative (CI< 0). Every contrast with a sizable unpadded signal collapses toward the padded axis, while the few negative cases sit in the lower-left, where B1 is already near chance. The random-forest panel is the reference criterion; logistic regression is shown only for robustness, as it over-separates on the near-constant execution features.

Cost. Padding is not free: it raises mean commit gas from 216,562 (B1) to 303,556 (B2), a 40.2% increase, and mean access gas from 546,876 to 753,310, a 37.7% increase. This overhead is the principal efficiency tradeoff of the design. Table 11 adds a single-point DEPTH $= 20$ cost characterization: the circuit compiles to 75,097 R1CS constraints, and mean local proof generation takes 3,881.5 ms, preceded by 190.8 ms of witness generation (about 4.1 s end to end). Gas, logs, and transaction objects are taken from the Polygon Amoy executed datasets; transaction hashes are stored in the B1/B2 executed datasets. Calldata lengths are the on-chain transaction input sizes fetched by hash from Polygon Amoy, and are constant across policies (B1 commit/access 164/452 bytes, B2 196/484). Proving time is local prover timing from the B1 run, not an on-chain measurement. Cost-vs-DEPTH scaling is left to future work because only DEPTH $= 20$ is compiled and evaluated here.

Table 10. Gas-padding ablation on Polygon Amoy: representative contrasts illustrating the padding effect. B1 (no gas padding) and B2 (deployed, randomized access-gas padding) are aligned on the same policy set. Supervised AUC is the random-forest score (the stronger of the two classifiers here; see Section 5.2); clustering reports K-Means ARI. $\Delta_{\text{leak}} > 0$ (defined in the text) means padding moved the attacker toward chance, reported as bootstrap mean with 95% CI. Each supervised row is, per experiment, the largest-signal contrast whose Δ_{leak} CI excludes zero (two for SPP), chosen to avoid cherry-picking. The full per-contrast distribution is in Figure 3.

Attack	Target	B1 (unpad.)	B2 (pad.)
Supervised (RF AUC; Δ_{leak} with 95% CI)			
SPP	`nestingDepth` `flat/medium`	0.847	0.486
	$\Delta_{\text{leak}} = 0.304$ CI$[0.262, 0.340]$		
SPP	`structureType` `trivial/and_or_mixed`	0.846	0.504
	$\Delta_{\text{leak}} = 0.291$ CI$[0.259, 0.327]$		
PCH	DUO POA	0.616	0.491
	$\Delta_{\text{leak}} = 0.092$ CI$[0.071, 0.114]$		
PI	`controlled_difference`	0.611	0.515
	$\Delta_{\text{leak}} = 0.102$ CI$[0.076, 0.129]$		
Unsupervised (K-Means ARI)			
PCH	ICD-10 chapter	0.064	−0.005
SPP	logic structure	0.043	−0.001
SPP	predicate count	0.054	0.001
Gas cost (mean, B1 → B2)			
Commit gas		216,562	303,556 (+40.2%)
Access gas		546,876	753,310 (+37.7%)

Table 11. Single-point cost profile at DEPTH = 20. Gas, logs, and transaction objects are measured from Polygon Amoy executed datasets; proving time is local prover timing from the B1 run. Calldata length is the on-chain transaction input size fetched by hash from Polygon Amoy; it is constant across all policies in each profile.

Metric	Value / source
Circuit size	75,097 R1CS constraints; 74,834 wires; DEPTH = 20
Public interface	2 public inputs plus 1 output
Verifier gas, unpadded B1	Commit 216,562; access 546,876 mean gas
Verifier gas, padded B2	Commit 303,556; access 753,310 mean gas
Event logs	Commit: 1 log / 180 bytes; access: 2 logs / 296 bytes
Calldata length	B1: commit 164, access 452 bytes; B2: commit 196, access 484 bytes (constant across policies)
Local witness time	190.8 ms mean (B1)
Local prove time	3881.5 ms mean (B1)

6. Discussion

The evaluation indicates that TPS-ZKPI removes the recoverable policy-dependent signals we can measure from normalized public-chain artifacts. Across all PCH, PI, and SPP tasks, supervised classifiers stay below the multi-seed permutation-test leakage criterion, and unsupervised clustering shows no recoverable structure: ARI is statistically indistinguishable from zero, and the residual NMI is consistent with finite-sample inflation once debiased against a permutation baseline. The gas-padding ablation (Section 5.8) sharpens this conclusion: the same attacks become measurably effective once gas padding is removed, which attributes the structure- and parameter-related protection specifically

to randomized gas padding rather than to weak attacks or insufficient sample size; content hiding rests instead on the commitment-only interface and the content-independent transcript normalization. Together with fixed-length policy representation, reusable interpretation, and commitment binding, these mechanisms limit the extent to which public-chain observers infer hidden policy content or structural properties from authorization transactions.

These results support a scoped privacy claim. The evaluation focuses on a metadata-only public-chain adversary that observes commitments, proofs, public parameters, calldata, events, and gas-related artifacts, but not TPS-side witness construction or off-chain policy material. Within this scope, transcript normalization together with randomized gas padding eliminates the recoverable policy-dependent signals we are able to measure across PCH, PI, and SPP, the padding adding a gas-cost overhead of roughly 38–40%. The main limitation is that this is an empirical claim, not an information-theoretic one: we do not claim distinguishability is zero, only that no modeled attacker recovers it above our multi-seed leakage criterion (isolated per-seed spikes above chance occur but do not reproduce across seeds). Stronger adversaries—compromised proof services, adaptive requester-side probing, or off-chain side channels—remain outside this scope and motivate the reduced-trust extensions discussed below.

The TPS trust assumption is the main architectural tradeoff. Moving confidentiality-sensitive proof generation to the TPS keeps policy-bound proving material away from requesters and public smart contracts while preserving on-chain verifiability, but it shifts part of the confidentiality burden to the service layer; the provider-operated TPS used here concentrates that burden at the provider rather than at an independent service (Section 3). This tradeoff does not affect liveness or accountability: the TPS or provider can refuse to produce a proof, which may be indistinguishable from a legitimate denial at the on-chain interface.

Two directions follow. First, accountable proof obligations—for example, on-chain commitments to serve requests together with timeout-with-evidence mechanisms—would make such refusals attributable. Second, the reduced-trust TPS instantiations of Section 3 (collaborative-SNARK or TEE-backed proving) would relax the trust concentration itself; realizing and evaluating them is left to future work.

7. Conclusion

This paper studied policy-private consent enforcement in blockchain-based healthcare data sharing under public-chain observability and an explicit TPS trust assumption. We proposed TPS-ZKPI, a Trusted Proof Service-assisted zero-knowledge approach that binds hidden provider-defined policies to on-chain commitments, evaluates Boolean-based consent policies through a reusable policy interpreter, and normalizes public verification artifacts to reduce metadata-level leakage. Across supervised and unsupervised attacks on PCH, PI, and SPP, no modeled adversary recovered hidden policy information above the chance baseline under a multi-seed permutation criterion, and a paired gas-padding ablation attributed this protection specifically to gas-transcript normalization—at a 38–40% gas overhead. Future work will extend the analysis to stronger adaptive adversaries, off-chain leakage, richer policy languages, reduced-trust proof generation, and privacy-preserving resource discovery.

Author Contributions: TODO.

Funding: TODO.

Institutional Review Board Statement: Not applicable.

Informed Consent Statement: Not applicable.

Data Availability Statement: TODO.

Conflicts of Interest: The authors declare no conflicts of interest.

References

1. Kakarlapudi, P.V.; Mahmoud, Q.H. A systematic review of blockchain for consent management. In Proceedings of the Healthcare. MDPI, 2021, Vol. 9, p. 137.
2. Welzel, C.; Ostermann, M.; Smith, H.L.; Minssen, T.; Kirsten, T.; Gilbert, S. Enabling secure and self determined health data sharing and consent management. *npj Digital Medicine* **2025**, *8*, 560.
3. Li, K.; Sai, A.R.; Urovi, V. Do you need a blockchain in healthcare data sharing? A tertiary review. *Exploration of Digital Health Technologies* **2024**, *2*, 101–123.
4. Béres, F.; Seres, I.A.; Benczúr, A.A.; Quintyne-Collins, M. Blockchain is watching you: Profiling and deanonymizing ethereum users. In Proceedings of the 2021 IEEE international conference on decentralized applications and infrastructures (DAPPS). IEEE, 2021, pp. 69–78.
5. Li, K.; Lohachab, A.; Dumontier, M.; Urovi, V. Privacy preservation in blockchain-based healthcare data sharing: A systematic review. *Peer-to-Peer Networking and Applications* **2025**, *18*, 1–53.
6. Lawson, J.; Cabili, M.N.; Kerry, G.; Boughtwood, T.; Thorogood, A.; Alper, P.; Bowers, S.R.; Boyles, R.R.; Brookes, A.J.; Brush, M.; et al. The Data Use Ontology to streamline responsible access to human biomedical datasets. *Cell Genomics* **2021**, *1*.
7. Rondelet, A.; Zajac, M. Zeth: On integrating zerocash on ethereum. *arXiv preprint arXiv:1904.00905* **2019**.
8. Williamson, Z.J. The aztec protocol. *URL: https://github. com/AztecProtocol/AZTEC* **2018**.
9. Nadler, M.; Schär, F. Tornado cash and blockchain privacy: a primer for economists and policymakers. *Federal Reserve Bank of St. Louis Review* **2023**.
10. Ibraimi, L.; Petkovic, M.; Nikova, S.; Hartel, P.; Jonker, W. Ciphertext-policy attribute-based threshold decryption with flexible delegation and revocation of user attributes. *IEEE Trans. Image process* **2009**.
11. Ullah, S.S.; Oleshchuk, V.; Pussewalage, H.S.G. A survey on blockchain envisioned attribute based access control for internet of things: Overview, comparative analysis, and open research challenges. *Computer Networks* **2023**, *235*, 109994.
12. Zhou, L.; Diro, A.; Saini, A.; Kaisar, S.; Hiep, P.C. Leveraging zero knowledge proofs for blockchain-based identity sharing: A survey of advancements, challenges and opportunities. *Journal of Information Security and Applications* **2024**, *80*, 103678.
13. Hu, R.; Ma, Z.; Li, L.; Zuo, P.; Li, X.; Wei, J.; Liu, S. An access control scheme based on blockchain and ciphertext policy-attribute based encryption. *Sensors* **2023**, *23*, 8038.
14. World Health Organization. International Statistical Classification of Diseases and Related Health Problems (10th Revision), 2019. Accessed: 2026-07-08.
15. Bethencourt, J.; Sahai, A.; Waters, B. Ciphertext-policy attribute-based encryption. In Proceedings of the 2007 IEEE symposium on security and privacy (SP'07). IEEE, 2007, pp. 321–334.
16. Ateniese, G.; Fu, K.; Green, M.; Hohenberger, S. Improved proxy re-encryption schemes with applications to secure distributed storage. *ACM Transactions on Information and System Security (TISSEC)* **2006**, *9*, 1–30.
17. Sasson, E.B.; Chiesa, A.; Garman, C.; Green, M.; Miers, I.; Tromer, E.; Virza, M. Zerocash: Decentralized anonymous payments from bitcoin. In Proceedings of the 2014 IEEE symposium on security and privacy. IEEE, 2014, pp. 459–474.
18. Wu, N.; Xu, L.; Zhu, L. A blockchain based access control scheme with hidden policy and attribute. *Future Generation Computer Systems* **2023**, *141*, 186–196.
19. Ardagna, C.A.; De Capitani di Vimercati, S.; Paraboschi, S.; Pedrini, E.; Samarati, P. An XACML-based privacy-centered access control system. In Proceedings of the Proceedings of the first ACM workshop on Information security governance, 2009, pp. 49–58.
20. Sheikhalishahi, M.; Tillem, G.; Erkin, Z.; Zannone, N. Privacy-preserving multi-party access control. In Proceedings of the Proceedings of the 18th ACM Workshop on Privacy in the Electronic Society, 2019, pp. 1–13.
21. Gabizon, A.; Williamson, Z.J.; Ciobotaru, O. Plonk: Permutations over lagrange-bases for oecumenical noninteractive arguments of knowledge. *Cryptology ePrint Archive* **2019**.
22. Campanelli, M.; Fiore, D.; Querol, A. LegoSNARK: Modular design and composition of succinct zero-knowledge proofs. In Proceedings of the Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security, 2019, pp. 2075–2092.
23. Liu, T.; Zhang, Z.; Zhang, Y.; Hu, W.; Zhang, Y. Ceno: Non-uniform, segment and parallel zero-knowledge virtual machine. *Journal of Cryptology* **2025**, *38*, 17.

24. Miller, T.; Alvarez, B.; Hoang, T. VTBC: Privatizing the Volume and Timing of Transactions for Blockchain Applications. In Proceedings of the 2023 32nd International Conference on Computer Communications and Networks (ICCCN). IEEE, 2023, pp. 1–10.
25. Boneh, D.; Sahai, A.; Waters, B. Functional encryption: Definitions and challenges. In Proceedings of the Theory of Cryptography Conference. Springer, 2011, pp. 253–273.
26. Secret Network. Secret Network Overview. https://docs.scrt.network/secret-network-documentation/overview-ecosystem-and-technology/secret-network-overview. Accessed: 2026-06-29.
27. Cheng, R.; Zhang, F.; Kos, J.; He, W.; Hynes, N.; Johnson, N.; Juels, A.; Miller, A.; Song, D. Ekiden: A platform for confidentiality-preserving, trustworthy, and performant smart contracts. In Proceedings of the 2019 IEEE European Symposium on Security and Privacy (EuroS&P). IEEE, 2019, pp. 185–200.
28. Groth, J. On the Size of Pairing-Based Non-interactive Arguments. In Proceedings of the Advances in Cryptology – EUROCRYPT 2016. Springer, 2016, pp. 305–326.

Disclaimer/Publisher's Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.